

exactly what the current receiver window is. An attacker can therefore send data that is marginally in or out of the victim's receiver window and confuse the NIDS.

Exploit RFC Interpretations

The various RFCs that provide the specifications for TCP (RFC 793, RFC 1323 and others) are quite complex and leave room for interpretation by the implementer. In addition, some TCP implementations have deliberately or accidentally deviated from the specifications. The result is the same TCP segment can be accepted or rejected by different TCP stack implementations, which gives attackers many opportunities to construct ambiguous TCP segments.

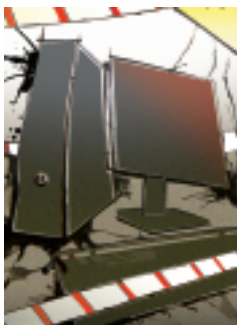
Preventing NIDS Evasion

The good news about all NIDS evasion techniques is that it is relatively easy to detect ambiguous packets. For example, if an intrusion detection system sees two overlapping TCP segments with different content, it is certainly an ambiguity and probably an evasion attempt. However, while detection is possible, it is not feasible to determine what the target host would do with the ambiguous packets. This means that it is impossible to determine whether the target host has been compromised or not. Moreover, when seeing multiple ambiguous packets over the same connection, an intrusion detection device knows that there is an attack but determining which attack is being attempted is impractical. The reason is that there are potentially millions of different combinations for the way the ambiguous packets would be reassembled but only a single combination that reveals the attack. Finding that single combination can take hours, days and even years, which is not practical for a real-time intrusion detection system.

This leads us to the following conclusion: Once an ambiguous packet is received at its target, the intrusion detection system becomes blind and cannot determine which attack is being attempted and whether it was successful or not. Meaning, the only way to avoid intrusion detection evasion is to prevent ambiguous packets from ever reaching their destination. This, of course, can only be achieved if the intrusion detection device is in the path of the data, i.e. running in-line.

Preventing Intrusions

The most significant drawback to a passive intrusion detection system is that it is passive and cannot control whether or not the attack is allowed to reach its target. Therefore, passive systems can really only be used for detecting attacks, rather than preventing them. However, it has been suggested that there are mechanisms available to passive devices that are able to stop attacks. These mechanisms are: Sending



The only way to avoid intrusion detection evasion is to prevent ambiguous packets from ever reaching their destination

TCP resets, Signaling to a firewall or router to block the traffic. This section will explain these mechanisms and demonstrate why they are unable to truly prevent an attack.

TCP Reset

The basic mechanism behind a TCP reset is that the intrusion detection device sends a reset packet to both the client and the server when it detects an attack. There are several problems with this approach. First, it takes a short while for the intrusion detection device to determine that an intrusion has been attempted and that a reset packet should be sent. During that time, the offending segment and, most likely, some of the packets that follow have already been transferred to the target network and reached their "victim." As a result, any reset that is sent upon detection may be too late. The second folly of TCP resets is that they only work for TCP protocols. They do not work for UDP-based protocols, such as DNS. The third, and most significant, problem has to do with the way TCP resets work. A TCP reset must carry a valid sequence number in order for the server to accept it. To be valid, the sequence number has to be within a certain, relatively small "receiver window." A sophisticated attacker can transmit its attacking segments so fast and have the receiver window change so rapidly that a passive device will have a very hard time determining which sequence number to put in its reset packets. Therefore, most attempts at a TCP reset would fail to stop the attack; sometimes it works, but usually it doesn't.

Firewall Signaling

Firewall signaling really is not prevention at all. Instead, it is an active feedback mechanism to the access control system (typically a firewall or a router). Firewall signaling gives the intrusion detection system the ability to tell a firewall what type of traffic should be "blocked" at the firewall. The desired outcome is an adjustment of the firewall policy to protect against future attacks. This sounds like a great idea, but, as it turns out, the danger of this method outweighs its benefits. It is relatively easy for an attacker to spoof the source of its attack and make the NIDS believe that it is being attacked by another IP address. If an attacker, for example, spoofed the IP address of a major Internet Service Provider's proxy server, such as America Online (AOL), and the NIDS signals the firewall to block that IP address, then service to the entire AOL community will be blocked. Sometimes, the attacker doesn't even need to spoof an IP address to achieve this result, they can simply send an attack as an AOL user. This makes the NIDS-Firewall combination an opening for simple, yet potentially devastating, denial-of-service (DoS) attacks. ■